

Leof. Kifisias 1-3, 11523 Athens

T: 210 6475 600 • E: contact@dpa.gr • www.dpa.gr

Athens, 10-01-2025

Protocol No.: 147

DECISION 3/2025

The Hellenic Data Protection Authority convened, upon the invitation of its President, in a meeting via teleconference on 18-06-2024, in order to examine the case referred to in the background of this document. Present at the meeting were the President of the Authority, Konstantinos Menoudakos, the regular members Charalampos Anthopoulos, Spyridon Vlachopoulos, Christos Kalloniatis, Grigorios Tsolias, the alternate member Nikolaos Faldamis in place of the regular member Aikaterini Iliadou, who, although duly summoned in writing, did not attend due to an impediment, and the regular member Konstantinos Lamprinouidakis as the rapporteur. Present, without voting rights, were Charis Simeonidou and Georgia Panagopoulou, special scientists – auditors, as assistants to the rapporteur, and Irini Papageorgopoulou, an employee of the administrative affairs department of the Authority, as secretary.

The Authority took into account the following:

With complaints numbered G/EIS/9060/24-07-2022 from A and G/EIS/9061/24-07-2022 from B, of similar content, the complainants are directing their grievances against the National Bank (hereinafter referred to as the respondent), alleging a possible incident of violation of their data and failure to satisfy their right of access under Article 15 of the GDPR. Specifically, according to the aforementioned similar complaints, on 26/3/2022, a customer of the National Bank, C, attempted to transfer the amount of €90 via the IRIS system from the iBank Pay application to the complainant A, using the mobile phone number of the latter, which he had saved in his contacts. However, according to the complaints, although the transaction was completed and a related confirmation was sent to the payer, the amount was not credited to the account of the first complainant A, but to the account of the second complainant B, with whom, as she states, she is not connected in any way. According to the aforementioned complaints, this transaction could not be canceled, and following the above incident, the complainants reported it to the respondent Bank and exercised their right of access to their personal data under Article 15 of the GDPR, in order to be informed about the apparent unjustified connection of their accounts, on the one hand through the complaint form on the Bank's website (<https://www.nbg.gr/el/footer/forma-paraponwn>) and on the other hand via email to the address dpo@nbg.gr of the Bank's Data Protection Officer, on 29/3/2022. However, as the complainants state, the Bank never responded to the complaint they submitted, nor was their request to the Data Protection Officer satisfied, although they were informed by the competent unit of the Bank within thirty (30) days from the submission of the request that it would make use of the additional sixty (60) days for the response, without any justification (note: in the said response, which is submitted as annex 5, it is stated that "due to the adverse current circumstances, it is not possible to satisfy your request within a one-month deadline"). Furthermore, according to the complaints, the respondent had not yet responded substantively to the aforementioned requests, while the same incident occurred on 19/6/2022, when an amount of €490 intended for the first complainant was credited to the account of the second complainant. In the context of investigating the complaints, the Authority, with document G/EXE/2877/15-11-2022, communicated the complaints and all relevant documents to the respondent Bank and invited it to express its views on the allegations, providing any relevant documentation. It specifically invited a) to inform the Authority whether and how it responded to the aforementioned access requests of the complainants, as well as where any

3

delay, b) to clarify whether it assessed the aforementioned factual incidents as a potential personal data breach and what actions it took regarding its handling. In its response no.

Γ/ΕΙΣ/12646/19-12-2022, the accused Bank initially described the operation of the i-bank Pay application, through which customers can transfer money instantly to their friends' accounts "simply by

knowing their phone number or their Facebook profile," and which is used with digital banking codes, prepaid cards, or i-bank Payband. Through this, two methods of sending money are provided: a) between customers of the National Bank who register for the p2p (person to person) service, through which they transfer money to their contacts who are also customers registered in the same service, and b) to those registered in the IRIS Online Payments service of the interbank system DIAS, who maintain an account either with the National Bank or another bank. The Bank clarified that if the recipient of the payment does not have the i-bank Pay application, it is sufficient for them to be registered in the IRIS Online Payments service, in which case the sending of money to them is done using either their phone number or their tax identification number (AFM). It also noted that for payments over 25 euros for friends and over 75 euros for merchants, in addition to the user's username and password, the entry of an OTP (One Time Password) is also required. Regarding the reported factual incidents, the Bank responded that following an investigation by the competent Unit, the following emerged:

- that the complainant B registered for the i-bank Pay p2p service selecting the phone number Ψ for the transfer, which according to the complaint belongs to the complainant A, "a fact that means that she had at that time the said phone available and entered the OTP message that was sent (to the phone device) during registration in the service. Consequently, in the systems of the National Bank, the said phone number was linked to B's deposit account for p2p transfers."
- that concurrently, A had registered for the IRIS Online Payments service of DIAS with the same phone number mentioned above (Ψ).

4

- that the transfer of the amount of €90 on 26.3.2022 was made by G using the i-bank Pay application to the mobile phone number of his choice (Ψ) and was credited immediately to an account that was linked to the service at that time, namely B's deposit account, and according to the terms of use of the i-bank Pay service, the transfer of money is not canceled or revoked.
- that after the customers' complaint, the necessary actions were initiated to investigate the incident, and the Bank made every possible effort to address it in cooperation with DIAS S.A., given its complexity. In this context, a message was sent to B that the issue is being examined, as well as a letter to A (dated 13/9/2022) requesting him to uninstall and reinstall the application with the note to return for further investigation in case of unresolved issues. Since the customer did not return, it was assumed that the issue had been resolved.
- that subsequently, following the Authority's document, "the case was re-examined and the issue that had arisen was fully resolved with some further systemic actions carried out by the competent Unit of the Bank." Specifically, the registration of complainant B in the p2p service with the phone number of complainant A was removed, while A was also requested to take the necessary corrective actions. The Bank states that the issue "concerned a systemic process of the application" and in order to confirm its resolution, a test transaction was carried out, which was successfully completed.
- that, therefore, this is not an incident of personal data breach, but rather a systematic parameterization, which was fully restored and was due to the initial registration of complainant B in the application with a phone number that, as it turned out, belongs to complainant A. Subsequently, following a related request from the complainant (with no. Γ/ΕΙΣ/135/10-01-2023), the Authority, with its document Γ/ΕΞΕ/72/10-01-2023, forwarded the Bank's response to the complainant, who subsequently returned with her supplementary document Γ/ΕΙΣ/3885/23-05-2023, in which she both disputes the Bank's claims and points out that

5

The Bank did not respond regarding the failure to satisfy the right of access to personal data. Specifically, the complainant states that in a telephone communication with the complained bank regarding the issue, when she asked when exactly the registration was made, she received the vague response "a long time ago" and emphasizes that she did not register in the application with the number of A, since in that case all transactions she would make through the application would have to be confirmed by A, which never happened. Furthermore, the complainant states that the same information

was not provided to A himself, while in his telephone communication with the Bank, after the second case of erroneous money transfer (on 19.6.2022), the Bank informed him that the said phone number (Ψ) was not linked to any of its customers. Subsequently, and given the above, the Authority deemed it necessary to conduct an administrative audit, based on the order no. Γ/ΕΞΕ/2564/16-10-2023 from the President of the Authority, which was transmitted with the document Γ/ΕΞΕ/2570/16-10-2023 to the complained bank. In the context of the audit, the same document requested the Bank to complete a questionnaire with a response deadline of 20/10/2023, prior to conducting an on-site audit at the Bank's premises on 25/10/2023, in order to complete the necessary data, evidence, and clarify the Bank's responses. Following a request for an extension of the above deadline, the questionnaire was answered with the document Γ/ΕΙΣ/7704/31-10-2023, as supplemented by the document Γ/ΕΙΣ/7728/31-10-2023 from the Bank.

In this document, responding to the questions, the Bank stated, among other important details:

- The phone Ψ, that is, the number which according to the complaint belongs to the complainant A, had been registered in the i-bank Pay application of ETE as a second phone number through which B could be located by her friends in order to receive money.
- It was found that the issue was due exclusively to an isolated human error in the context of the integration of the IRIS pay service into Mobile Banking. Specifically, it was determined that during the aforementioned systemic integration that took place in June 2020, the second phone that the customer had registered in the application was activated on her account in i-bank Pay. It is noted that the competent Unit of the Bank is investigating the potential activation of other phone numbers, directly checking all users of the application.

Following this, on Wednesday 1/11/2023, the on-site audit was conducted at the premises of the complained bank by the auditors of the Authority, Georgía Panagopoulou and Cháris Symeonídou. During the audit, the following executives from the Bank were present: D, Head of the Business Regulatory Compliance & Client Conduct Division of the Bank and the Group, E, Head of the Digital Transformation Division, S, Data Protection Officer, Z, Head of the Compliance and Quality Assurance Sector, H, Head of the Client Conduct Sector of the Bank, Th, Head of the Application Management, Architectural Services, and IT Supervision Issues Sector of the Bank and the Group, I, Deputy Data Protection Officer of the Bank, and K, Head of the Payments & Digital Services Compliance Subdivision.

As emerged during the on-site audit, the complained bank indeed found that due to a systemic error, while the second phone that the customer had registered in the application should have been confirmed with OTP in order to be validated and linked to her name, it was validated and entered during the integration of the IRIS pay service into the complained bank's Mobile Banking. That is, the code that was executed also entered the phones that were in a "pending verification" state and which had not been validated with OTP (one-time password). This erroneous process ran for all phones that were in this state. During the audit, the need to submit a notification of a personal data breach incident was also recognized, and it was stated that the operation of the i-bank Pay application has been suspended until the incident is fully investigated.

7

The following day, the reported and controlled Bank submitted notification of a personal data breach incident under reference number Γ/ΕΙΣ/7785/02-11-2023, in accordance with Article 33 of the GDPR. The submitted notification form and the relevant fields include, among other things, the following details regarding the incident:

- Approximate number of files related to the incident:
One (1) file (table in the i-bank Pay/mobile banking database)
- Approximate number of individuals affected by the incident:

There is one confirmed incident involving two individuals. The competent Unit of the Bank is investigating whether other customers have been affected.

- Detailed description of the measures taken prior to the incident:

According to the specifications of the i-bank Pay application, in order for a user to link their mobile

phone to a specific product (deposit account / prepaid card / payband), they initially entered the Internet / Mobile Banking codes they held with the Bank and then their mobile phone number, confirming the relevant connection by entering the OTP sent by the Bank for this purpose. - The competent Unit of the Bank had conducted all necessary checks for the proper implementation of the application (functional tests) and, by presumption, the service operated without issues since its introduction in 2016. - Specifically, in order to address the potential issue of sending money to the wrong recipient (assuming, of course, that such an occurrence would be due to an incorrect entry of the phone number in the sender's contacts and NOT due to a problem with the bank), we had provided for the beneficiary's name to be displayed masked before the completion of the transfer, allowing for a final check and confirmation by the sender. - Additionally, as part of the integration of the i-bank Pay service into Mobile Banking and following the removal of the ability to link a card to the service, the customer could now link only the mobile phone that is registered/confirmed in the Bank's customer-centric system.

8

- Nature of the potential consequences for the individuals affected by the incident:
Accidental unauthorized (without OTP) activation of a mobile phone that the individual had registered in the i-bank Pay application, which could potentially lead to financial loss and unjust enrichment.
- Have you informed the individuals affected by the incident?
(YES/NO/NOT YET, BUT THEY WILL BE INFORMED / IT HAS NOT YET BEEN DECIDED WHETHER THEY SHOULD BE INFORMED)

The customers have been verbally informed about the resolution of the issue and the correction of the incorrect phone number. They will soon receive written notification regarding the results of the recent investigation. Furthermore, once the investigation is completed, any other affected individuals will also be informed.

- Description of the measures taken to address the breach:
 - A. Immediate suspension of the i-bank Pay application
 - B. Checking for any similar issues across all users of the application (total i-bank pay users: approximately 76,000)
 - C. Checking for any disclosure of user data from the issues that may arise from action B.
 - D. Designing and implementing additional corrective measures, if required, such as restoring data to its previous state, establishing additional security safeguards, etc.
 - E. Confirmation via the display of a splash banner in the Mobile Banking application on the mobile phone registered in the IRIS Pay service
 - F. Correction of the mobile application so that when the user requests the activation of a phone connection that is pending, it can only be done with a verification code and only within a reasonable time frame from the moment the pending request is created, and in no case should automatic activation of the phone be executed.

9

With its letter G/EIS/8183/17-11-2023, the Bank informed the Authority that further investigation of the case is ongoing on its part, in order to submit within the coming days a supplementary notification with additional information. Subsequently, with its letter G/EIS/8348/23-11-2023, the Bank provided the Authority with the transaction history of B in the Bank's i-bank Pay application, as transmitted by the competent Unit of the Bank, which reflects both the initial registration in the service and the actions related to the linking of phone numbers to her account.

From this history, the following emerges:

The complainant registered for the service on 14/4/2019, at 21:02:04 via the i-bank pay application, following the registration process as shown in her transactions. She then selected an account (...) and mobile phone number (X). Immediately after, she accepted the terms and entered the sms-otp (verification code sent to mobile X).

On 08/07/2019, the complainant changed the phone number linked to the i-bank pay service and entered mobile number Y, without entering a confirmation code (sms otp). This action remained in a

"pending" state.

She then entered mobile number X and subsequently verified it by entering the otp sent by the bank. Later, on 24/06/2020, she logged into the mobile application and her registration was automatically completed, as the call for device registration on mobile was made automatically.

In the log file, the status of mobile Y appears as "pending" (status = pending) while that of X is active (status = active).

Subsequently, with the letter G/EIS/980/8-2-2024, the data controller completed the analysis of the incident with the following details:

- Start time of the incident (year/month/day/hour):

Date of mobile banking application upgrade 24.06.2020

10

- End time of the incident (year/month/day/hour)

Date of definitive discontinuation of the ibank Pay application (01.11.2023)

- Time you became aware of the incident (year/month/day/hour)

On 30/10/2023, the first incident was confirmed and the investigation process was initiated to identify any other related incidents.

- How you became aware of the incident

The incident was identified following an investigation by the Bank's Digital Transformation Directorate, as part of a renewed investigation of a complaint in light of the administrative audit of your Authority.

- Nature of the incident:

During the integration of the IRIS Pay service into the Bank's Mobile Banking application, mobile phones that had been registered by customers were inadvertently activated in the Bank's i-bank Pay application, for which they had not completed their verification by entering a one-time password (OTP).

- Cause(s) of the incident:

Isolated Software Error

- Number of files (approximately) related to the incident:

One (1) file (table in the i-bank Pay/mobile banking database)

- Number of persons (approximately) related to the incident:

In addition to the incident for which we had informed you with our initial notification on 02.11.2023, it was confirmed after investigation that there are an additional 24 cases of customers for whom a phone was inadvertently activated in the i-bank pay application for which they had not completed their verification by entering a one-time password (OTP).

- Nature of the potential consequences for the individuals affected by the incident:

11

Inadvertently unauthorized (without OTP) activation of mobile phones that had been registered by the customers themselves in the i-bank Pay application, which could potentially lead to financial loss and unjust enrichment. In this context, based on our relevant investigation, it was found that 38 erroneous cash transactions were made by 33 customers for a total amount of €2,149.66.

- Have you informed the individuals affected by the incident?

(YES/NO/NOT YET, BUT WILL BE INFORMED / NOT YET DECIDED IF THEY SHOULD BE INFORMED)

The customer related to the first confirmed incident for which we made initial notification on 02.11.2023 has already received supplementary information from the Bank regarding her case.

Additionally, the Bank will provide financial compensation to the customers affected by the issue and will inform them accordingly.

- Date on which you informed the individuals (year/month/day):

07.11.2023 (notification of the customers related to the first confirmed incident)

- Date on which you will inform the individuals (year/month/day or UNDETERMINED, if not specified): Gradual notification, which is expected to be completed by February 2024.

Attached are the relevant messages that were sent.

- Description of the measures taken to address the breach:

A. The immediate suspension of the i-bank Pay application

B. The verification of the existence of any similar issues across all users of the application (total users of i-bank pay: approximately 76,000)

C. The verification of any disclosure of user data from the issues that may arise from action B.

12

D. The design and implementation of additional corrective measures, if required, such as restoring the data to its previous state, establishing additional safeguards, etc.

E. Confirmation through the display of a splash banner in the Mobile Banking application of the mobile phone registered in the IRIS Pay service.

F. The correction of the mobile application so that when the user requests the activation of a phone connection that is pending, it can only be done with a verification code and only within a reasonable time frame from the moment the pending status is created, and in no case should there be an automatic activation of the phone.

G. The financial restitution of the individuals affected by the incident.

Following the above, the Authority, with its calls G/EXE/532/12-02-2024, G/EXE/526/12-02-2024, and G/EXE/531/12-02-2024, respectively, summoned the complainants A and B and the complained party to a hearing before the Plenary of the Authority on 20/2/2024, in order to present their views on the case. During the session on 20/2/2024, the discussion of the case was postponed at the request of the complainant to 12/3/2024. At the session on 12/3/2024, the complainants A and B were present, with their attorney Magda Elena Pavlikovska (A.M. DSA ...), and on behalf of the National Bank were E, Assistant General Director of Innovation and Digital Partnerships, Z, Head of the Compliance and Quality Assurance Sector, H, Head of Customer Behavior Sector, D, and L, Directors of Business Regulation Compliance and Customer Behavior of the Bank and the Group, S, Data Protection Officer of the National Bank, and I, Deputy Data Protection Officer. During the session, a deadline was granted for the submission of a memorandum, and the parties submitted their documents in a timely manner: B submitted the G/INS/2993/01-04-2024 memorandum, the National Bank submitted the G/INS/2994/01-04-2024 memorandum, while A, with his G/INS/2963/29-03-2024 document, stated that he withdraws his complaint number G/INS/9060/24-07-2022 due to satisfactory clarifications provided by the complained Bank during the session of the Plenary of the Authority that took place on 12/03/2024.

Both during the session and with her memorandum, the complainant B reiterated the points made in her complaint, emphasizing that multiple communications and the submission of the complaint to the Authority were necessary for the Bank to address the issue, and asserting that up to that point, no convincing response had been provided by the Bank regarding the incident. The complainant particularly pointed out the delay in fulfilling her right of access, which was exercised on 29/3/2022 and ultimately, following the notification on 29/4/2022 that an extension would be used for two months "due to adverse current circumstances," which was never explained, was eventually fulfilled late on 7/11/2023, and in her opinion, not adequately, since the Bank's response stated that "by mistake, A's mobile was activated on her profile," but her personal data processed by the Bank regarding the incident were not provided to her. Finally, the complainant mentioned that she received responses "via telephone and electronic correspondence which were possibly based on data correlation due to interpersonal relationships."

The National Bank, both through its representatives during the hearing and with its memorandum, stated the following: Indeed, at the end of March 2022, it received a complaint regarding an issue related to the ibank Pay application, which had been operating since 2016 without problems. Specifically, the complainants informed the Bank that on 26/3/2022, a money transfer was made from

the account of the application user G to the mobile phone Ψ, which at that time was linked to the account of the complainant B, while, according to the customers, the funds should have been credited to a different customer's account, that of complainant A, and requested an investigation into the incident. Furthermore, on 29/3/2022, the customers jointly submitted a request to exercise their right of access to their personal data. According to the Bank, the DPO office received the request and initiated the necessary actions to investigate the matter, initially checking whether any malfunctions had been observed regarding the use of the

14

application. Given the complexity of the case, a letter was sent on 29/4/2022 to the complainant B, through which the Bank informed her that the required actions were underway and her request would be fulfilled within three months of its submission. Since registration in the application required the entry of the mobile phone number by the user themselves, the Bank considered that the registration of the complainant had been successfully completed with OTP and investigated the problem in the subsequent stages, after registration, focusing on A. In a phone call that the complainant had on 19/6/2022 with the Bank to inform them about a second incident, during which money from a different sender intended for her had again ended up in B's account, the Bank's representative provided information regarding the registration process for the IRIS pay service, either through the i-bank Pay application or through Mobile Banking, and for the data required for registration, she suggested that the complainants submit a new contact form to the Bank with details about the second transaction and it was agreed that A would be considered the first and primary party involved in the case, as he was the one who could suffer financial damage from the issue. From this initial investigation, it emerged that no malfunction had been observed in the application and that the phone Ψ had been declared by the complainant B as a second phone number based on which she could be located by friends to receive money, while in the data maintained by the Bank for A, there was no registered mobile phone but only a landline. Subsequently, on 13/9/2022, the Bank sent A an update via email with specific instructions to resolve the issue (unregistration and re-registration), with a note to follow up in case of unresolved issues, and since the customer did not follow up, the Bank considered that the problem had been resolved. Then, following the document from the Authority dated 15/11/2022, which notified the Bank of the complaints under consideration, the Bank re-investigated the issue, contacted A again, and after the necessary systemic actions were taken to deactivate the second phone in the application, as well as a test payment to confirm that the issue had been fully resolved, the Bank contacted B on 16/12/2022 and sent a response to the Authority on the same day. Weighing the results of the process, it was determined that the conditions for reporting a breach incident or recording an incident according to the GDPR were not met, as, on the one hand, it concerned an isolated incident and, on the other hand, it did not pose a risk to the rights and freedoms of individuals. Subsequently, and in light of the administrative review by the Authority according to the document dated 16/10/2023, the Bank states that it conducted a thorough and more extensive review of all procedures, without taking any stage for granted, and thus identified the problem: The i-bank Pay application was available until the year 2018 only for customers of the National Bank. In 2018, the IRIS system of DIAS began to operate, and in 2020, ibank was integrated into IRIS. Specifically, it was found that due to an isolated software error during the integration of the IRIS pay service into Mobile Banking in June 2020, the second phone that B had registered in the application was inadvertently activated on her account in i-bank Pay, without her having completed the confirmation via one-time password (OTP). The Bank reported the incident as a personal data breach on 2/11/2023, sent a supplementary update to the complainants (Attachments 7 and 8 to its memorandum), and proceeded with further investigation of the issue to identify any similar incidents among all users of the application, concluding that any phone numbers that were in pending status, meaning they had not been confirmed with OTP, were activated on the corresponding accounts. The Bank clarified that the error only affected the ibank Pay application, and not the IRIS system as a whole, thus affecting only payments from holders of accounts at the National Bank. In this case, the complainant B, while she had successfully registered in April 2019 with her own phone number, in July 2019 (8/7/2019) attempted to make a phone number change to A's number, without the change being completed with OTP, and thus the registration of the new number remained

pending and B's actual number remained active. However, during the integration of the application into IRIS in 2020, the second number was activated and linked to her bank account.

16

B. The Bank clarified that A did not have an account at the National Bank, and thus his number was not registered in its systems. According to the Bank's claims, it was a completely unexpected "bug" in the system, which was very difficult to locate, while the initial investigation by its technicians led to the initial erroneous response to the complainants. From the thorough check of similar issues across all users of the application (76,000), it was found that the inadvertent activation of phones had occurred for another 24 customers, and it was determined that 38 erroneous transactions had been made, totaling 2,149.66 euros. Regarding the delay in satisfying the right of access, the Bank reiterated that it was a problem very difficult to identify since it was not located where it was being searched, but was due to a misconfiguration during the upgrade of the application, emphasizing that it was the Bank's intention to timely inform the complainants; however, the issue was under investigation throughout the period until November 2023, and in any case, it ensured to keep them informed until the completion of the investigation. Finally, in its memorandum, the Bank states that, after suspending the i-bank Pay application from 2-11-2023 and sending supplementary responses to the complainants on 7-11-2023, it has planned and implemented additional corrective measures, such as conducting checks to ensure that phones with pending connection requests for a long time are not connected, and the periodic, regular deletion of pending phones in accounts, as well as the following actions:

- Confirmation via splash banner display in the Mobile Banking application of the mobile phone registered in the IRIS Pay service
- Correction of the mobile application so that when the user requests the activation of a phone connection that is pending, it can only be done with a verification code and only within a reasonable time from the moment of the pending status, and in no case should automatic phone activation be executed.

17

- Communication with customers who were found to have inadvertently activated mobile phone connections with their accounts and financial restoration of the individuals affected by the incident.

The Authority, after examining the file's elements and having heard the rapporteur and the clarifications from the assistant rapporteur, after thorough discussion

CONSIDERED IN ACCORDANCE WITH THE LAW

1. From the provisions of Articles 51 and 55 of the General Data Protection Regulation (Regulation (EU) 2016/679 – hereinafter, GDPR) and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data. Specifically, from the provisions of Articles 57 paragraph 1 subparagraph (f) of the GDPR and 13 paragraph 1 subparagraph (z) of Law 4624/2019, it follows that the Authority has the competence to address the complaints of B and A against the National Bank of Greece S.A. and to exercise, respectively, the powers conferred upon it by the provisions of Articles 58 of the GDPR and 15 of Law 4624/2019.

2. With Article 5 paragraph 1 of the General Regulation (EU) 2016/679 for the protection of natural persons against the processing of personal data (hereinafter GDPR), the principles that must govern a processing are established. According to Article 5 paragraph 1 (a) and (f) GDPR, "1. Personal data: (a) shall be processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency'), [...] (f) shall be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures."

18

Organizational measures ("integrity and confidentiality"), while as noted in the Preamble of the

Regulation, "Personal data should be processed in a manner that ensures appropriate protection and confidentiality of personal data, including to prevent unauthorized access to such personal data and to the equipment used for processing them or the use of such personal data and the said equipment" (Recital 39 in fine). Furthermore, according to the principle of accountability explicitly defined in the second paragraph of the same article, which constitutes a cornerstone of the GDPR, the data controller "is responsible for and is able to demonstrate compliance with paragraph 1 ("accountability")." This principle entails the obligation of the data controller to be able to demonstrate compliance with the principles of Article 5 paragraph 1.

3. According to Article 15 paragraphs 1 and 3 of the GDPR "1. The data subject has the right to obtain from the data controller confirmation as to whether or not personal data concerning them is being processed and, if that is the case, the right of access to the personal data and to the following information: [...] 3. The data controller shall provide a copy of the personal data undergoing processing. [...] If the data subject submits the request by electronic means and unless the data subject requests otherwise, the information shall be provided in a commonly used electronic format." Additionally, according to Article 12 of the GDPR "1. The data controller shall take appropriate measures to provide the data subject [...] with any communication in the context of Articles 15 [...] 2. The data controller shall facilitate the exercise of the rights of data subjects provided for in Articles 15 [...] 3. The data controller shall provide the data subject with information on the action taken in response to a request under Articles 15 to 22 without undue delay and in any event within one month of receiving the request. This period may be extended by two further months where necessary, taking into account the complexity of the request and the number of requests. The data controller shall inform the data subject of any such extension within one month of receiving the request, as well as of the reasons for the delay. [...] 4. If the data controller does not take action on the request of the data subject, the data controller shall inform the data subject without undue delay and at the latest within one month of receiving the request, of the reasons for not taking action and of the possibility of lodging a complaint with a supervisory authority and seeking a judicial remedy." From the above provisions, it follows that the right of access of the data subject to their personal data is established primarily to ensure that the data subject is assured of the accuracy and lawful nature of the processing of their data. Therefore, for the satisfaction of the right of access, the invocation of a legal interest is not required, as it is inherent and constitutes the basis of the right of access of the data subject to obtain information concerning them that has been recorded in a file maintained by the data controller, so that the fundamental principle of law for the protection of personal data, which consists of the transparency of processing as a prerequisite for any further scrutiny of its legality by the data subject, is realized.

4. According to the provision of Article 24 paragraph 1 of the GDPR: "1. Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is performed in accordance with this Regulation. These measures shall be reviewed and updated as necessary," while according to the provisions of paragraphs 1 and 2 of Article 32 of the GDPR regarding the security of processing, "1. Taking into account the latest developments, the cost of implementation, and the nature, scope, context, and purposes of the processing, [...]"

20

of processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor implement appropriate technical and organizational measures to ensure an adequate level of security against these risks, including, among others, as applicable: a) pseudonymization and encryption of personal data, b) the ability to ensure the confidentiality, integrity, availability, and resilience of processing systems and services on an ongoing basis, c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, d) a process for the regular testing, assessment, and evaluation of the effectiveness of the technical and organizational measures to ensure processing security. 2. In assessing the appropriate level of security, particular account shall be taken of the risks

arising from the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed.

5. According to the provision of Article 25 paragraphs 1 and 2 of the GDPR (Data protection by design and by default): “1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons posed by the processing, the data controller shall implement effective, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to implement data protection principles, such as data minimization, and to integrate the necessary safeguards into the processing in such a way that the requirements of this Regulation are met and the rights of data subjects are protected. 2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data which are necessary for each specific purpose of the processing are processed. This obligation applies to the scope of personal data collected, the extent of their processing, the retention period, and their accessibility. In particular, the measures in question ensure that, by default, personal data are not made accessible without the intervention of the data subject to an indefinite number of natural persons.”

6. According to Article 4 paragraph 12 of the GDPR, a personal data breach is defined as “a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed.” According to the Guidelines of the Article 29 Working Party of Directive 95/46/EC (now GDPR) dated 06-02-2018 on the Notification of Personal Data Breaches (“Guidelines on Personal data breach notification under Regulation 2016/679” WP 250 rev. 1), one type of personal data breach is categorized based on the security principle of “confidentiality,” when unauthorized access to personal data is detected (“confidentiality breach”): “A breach may potentially have various significant adverse consequences for individuals, which can lead to physical, material, or moral harm. The GDPR explains that this harm may include loss of control over their personal data, restriction of their rights, discrimination, identity theft or fraud, financial loss, unlawful reversal of pseudonymization, damage to reputation, and loss of confidentiality of personal data protected by professional secrecy. It may also include any other significant economic or social disadvantage for these individuals (see also recitals 85 and 75)” (Chapter I.B.3). As noted in the Guidelines 9/2022 of the GDPR on the notification of personal data breach incidents.

22

According to the GDPR, “security incidents are not limited to cases (threat models) where an attack originating from an external source is carried out against an organization, but include incidents arising from internal processes that violate the principles of data processing security” (p. 8, footnote 16).

7. Data breach incidents must be reported to the Authority within 72 hours from the moment the data controller becomes aware of them, in accordance with Article 33(1) of the GDPR, which states that “1. In the event of a personal data breach, the data controller shall notify without undue delay and, where feasible, within 72 hours of becoming aware of the breach, the supervisory authority competent under Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. When the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay.” The notification must contain at least the minimum information referred to in paragraph 3 of Article 33 of the GDPR, while according to paragraph 5 of the same article “The data controller shall document any personal data breach, comprising the facts relating to the personal data breach, its effects, and the remedial actions taken. This documentation enables the supervisory authority to verify compliance with the present article.” Regarding the time of knowledge of the incident by the Data Controller, the aforementioned Guidelines of the EDPB (wp 250) state the following: “As detailed above, the GDPR requires that in the event of a breach, the data controller shall notify the breach without undue delay and, where feasible, within 72 hours of becoming

aware of the breach. This raises the question of when a data controller can be considered to have 'knowledge' of a breach. The EDPB considers that a data controller should be deemed to have acquired 'knowledge' when the data controller has a reasonable degree of certainty that a security incident has occurred that results in a risk to personal data. However, as previously mentioned, the GDPR requires the data controller to implement all appropriate technical and organizational measures for the prompt detection of any breach and the immediate notification of the supervisory authority and the data subjects. It also states that it should be established that the notification was made without undue delay, taking into account in particular the nature and severity of the data breach, as well as the consequences and adverse effects for the data subject. In this way, the data controller is obliged to ensure that it acquires 'knowledge' of any breaches in a timely manner so that it can take appropriate action. The exact point in time when a data controller can be considered to have 'knowledge' of a specific breach will depend on the circumstances of the particular breach. In some cases, it may be relatively clear from the outset that a breach has occurred, while in others, it may take some time to ascertain whether personal data has been compromised. However, emphasis should be placed on timely action to investigate an incident to determine whether personal data has been breached and, if so, to take remedial measures and notify, if required." Furthermore, the breach must also be communicated to the data subject, where appropriate and in accordance with the provisions of Article 34(1) and (2) of the GDPR: "1. When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall notify the personal data breach to the data subject without undue delay. 2. The notification to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33(3)(b), (c), and (d)." According to 24

From Article 33 of the GDPR, not only arises the obligation to notify the supervisory authority of breach incidents but also the obligation to actively investigate any potential incident, provided that the data controller becomes aware of relevant indications. Otherwise, the data controller could easily bypass their obligation to notify the supervisory authority of breach incidents by simply ignoring indications of a potential incident and avoiding to gain certainty and to "become aware" of it according to the above provision. Furthermore, from paragraph 3 of Article 33 of the GDPR (content of the notification), it follows that the data controller is obliged to promptly investigate the elements mentioned therein, so as to be able to include the relevant information in the notification to the authority (nature of the breach, categories and number of affected subjects, number of affected files, possible consequences of the breach, measures taken or proposed to address the breach, measures to mitigate potential adverse consequences), as well as to assess the risk to the rights and freedoms of the subject,³ in order to decide whether notification is required to them under Article 34 of the GDPR, while paragraph 5 of Article 33 of the GDPR explicitly states the obligation to maintain documentation for all the above processes (see also Decision 35/2023 of the DPA).

8. In this case, from the examination of all the elements of the file and following the hearing process, the following emerged: On 14/4/2019, the complainant, who maintained an account at the National Bank, registered in the i-bank Pay application, linking her bank account with her mobile phone number (X), in order to receive payments from third parties using this number. On 8/7/2019, the complainant, possibly by mistake, attempted to change the declared phone number in the application, filling in the number of A (Ψ), but this change was not completed with the confirmation process via the sending of a one-time password (OTP). Thus, the registration of the new number remained pending while the complainant's actual number (X) remained active in the application and linked to her bank account. However, during the integration of the i-bank Pay application into the IRIS Online Payments service of the interbank system DIAS, which the National Bank proceeded with in 2020, the second number (Ψ), which was in a pending state, was activated and linked to the complainant's bank account. The issue was due to incorrect configuration on the part of the bank during the upgrade of the mobile banking application, which the Bank attributes to an isolated human error. Although, as it was found, A had an account at the National Bank, only a landline number was included in his customer profile, while his mobile phone number was not registered in the Bank's systems. A used the IRIS Online Payments

system through an account he had at another bank, which is linked to his mobile phone number (Ψ). The incorrect activation of this number in B's profile and its connection to her bank account resulted in an attempt by the third party C to transfer the amount of €90 to A via the i-bank Pay application on 26/3/2022, with the transfer being made to B's account. Furthermore, it was found that despite the immediate notification of the Bank by the complainants regarding the issue and their exercise of the right of access (on 29/3/2022), the Bank merely advised A to uninstall and reinstall the application, while it proceeded to investigate the matter only after it was notified of the complaints submitted to the Authority. However, this initial investigation did not reveal the essence of the issue and led to the provision of incorrect information to the complainants, namely that A's number had been activated by B using a one-time password (OTP). After

26

For several months and following the on-site inspection by the Authority at the Bank (end of October 2023), the latter proceeded with further investigation of the issue, which resulted in the identification of the problem. Thus, in November 2023, the Bank suspended the application of i-bank Pay, submitted a notification of a breach incident to the Authority, re-informed the complainants, and conducted a thorough check of related issues for all users of the application (76,000), from which it emerged that the erroneous activation of phones had occurred for another 24 of its customers, while 38 erroneous transactions had been made totaling €2,149.66. The Bank reported that it contacted these customers and financially compensated the individuals affected by the incident. Furthermore, the Bank stated that it took additional corrective measures to prevent similar incidents in the future, such as conducting regular audits, periodic deletion of pending phone numbers on accounts, implementing measures so that the activation of phone connections occurs only with a verification code and only within a reasonable time frame from the moment of the pending issue, and under no circumstances should automatic phone activation be executed, with the mobile phone registered in the IRIS Pay service being confirmed through the display of a splash banner in the Mobile Banking application.

9. Based on the above data, the Authority finds that the actions and omissions of the National Bank, as the data controller, constitute:

i. Violation of the fundamental principles of accuracy, integrity, and confidentiality of data (Article 5, paragraph 1, subparagraph d and e of the GDPR) in conjunction with deficiencies in appropriate security measures (Article 32 of the GDPR), such as an insufficient change management process and inadequate functionality and quality control of the software, resulting in the failure to identify errors before it went into production and consequently, as previously mentioned, the systemic erroneous connection of mobile phones of data subjects with third-party bank accounts, the maintenance of inaccurate personal data, and ultimately the disclosure to third parties of information concerning the banking transactions of the data subjects.

27

ii. Violation of Article 25 of the GDPR regarding data protection by design and by default, since, as it emerged, the aforementioned violation occurred due to faulty design (configuration) of the integration process of the i-bank Pay application into the IRIS Online Payments service of the interbank system DIAS, which the National Bank undertook in 2020, resulting in the non-requirement of confirmation of pending numbers with a one-time code (OTP) in order to activate and connect them with the bank accounts of those users who had such numbers pending.

iii. Violation of Articles 33 and 34 of the GDPR in the context of handling the breach incident, given that from the moment the reported Bank became aware of the issue from the complainants, it did not take actions to investigate the incident, which it was obligated and able to do, as was established when the Authority informed it about the conduct of an administrative audit.

iv. Violation of the right of access of the complainants under Article 15 of the GDPR, as the Bank did not handle the requests from 29/3/2022 of the complainants as access requests under Article 15 of the GDPR, but limited itself to providing information about the incident only to A, which was initially incorrect, as previously mentioned. The correct information to the complainants regarding the said incident took place on 7/11/2023 and only after the conduct of an administrative audit by the Authority.

10. Based on the above, the Authority finds that there is a case to exercise its corrective powers under Article 58 paragraph 2 of the GDPR concerning the identified violations and that, based on the circumstances established, an effective, proportionate, and deterrent administrative monetary fine should be imposed under Article 83 of the GDPR, in accordance with the provision of Article 58 paragraph 2 subparagraph i of the GDPR. Furthermore, the Authority took into account the criteria for assessing the fine as defined in Article 83 paragraph 2 of the GDPR, paragraphs 4 subparagraph a) and 5 subparagraph a) and b) of the same article that apply to the present case, the Guidelines for the application and determination of administrative fines for the purposes of Regulation 2016/679 issued. 28

On 03-10-2017, from the Article 29 Working Party (WP 253) and the Guidelines 04/2022 of the European Data Protection Board for calculating administrative fines under the General Regulation, as well as the actual data of the examined case, particularly the criteria and specific circumstances listed below:

- that the nature of the violation concerns fundamental principles of the GDPR,
- that the processing is part of the core activities of the data controller,
- that the number of affected subjects was small,
- that the categories of personal data involved in the processing entail a high risk, as financial data, while the financial damage in this specific case was small due to minor amounts transferred to the wrong bank account,
- that there was no proper assessment of the complaints of the subjects and their requests for access to their personal data, while the systemic error was identified only after the Authority's inspection,
- that, in any case, after the identification of the problem, the Bank took measures to remedy the damage suffered by the subjects and to prevent similar incidents in the future, and
- that the turnover (gross revenue) of the Bank for the last financial year (2023) amounted to approximately 2.6 billion euros.

FOR THESE REASONS
THE AUTHORITY

A. Imposes on the National Bank of Greece S.A., as the data controller, based on Article 58 paragraph 2 point (h) of the GDPR, an administrative fine of one hundred thousand (100,000€) euros, for the established violations of Articles 5 paragraph 1 point (d) and (e) in conjunction with Article 32 of the GDPR, and Articles 25, 33, and 34 of the GDPR, according to what is stated in points i.-iii. of Recital 9 above.

B. Imposes on the National Bank of Greece S.A., as the data controller, based on Article 58 paragraph 2 point (h) of the GDPR, an administrative fine of twenty thousand (20,000€) euros, for the established violation of the right of access of the complainants under Article 15 of the GDPR, according to what is stated in point iv. of Recital 9 above.

The President

The Secretary
Konstantinos Menoudakos
Irina Papageorgopoulou